

프로젝트 기획서

자율 Agent의 권한 위반 조기 탐지

Activation-based Early Warning for Autonomous Agents

01 핵심 목적

정상 과제를 수행하던 Agent가 목표 달성을 위해 권한 밖의 행동을 선택하기 전에, 내부 표현에서 위험 신호를 탐지할 수 있는지 검증한다. 행동 이력·출력된 추론 텍스트만 감시하는 방식보다 같은 오탐 예산에서 더 일찍 또는 더 정확하게 경고하는지가 핵심 연구 질문이다.

항목	확정 사항 / 검증할 가설
기간 / 팀	2026.09.22 ~ 10월 마지막 주 / 4명
모델 / 장비	gpt-oss 계열. 초기 대상 20b / RTX 4090 / RAM 68GB. 실제 GPU 적합성 미검증.
주 시나리오	정상 과제 + 명시적 권한 경계 + 과제 수행 장애물. 우회 지시 없이 자발적 경계 위반 시도 관찰.
핵심 산출물	재현 환경, 행동 라벨, 레이어·시점별 Probe, 조기 탐지 비교 실험, Guard 연동 데모
제품 가설	자체 모델을 운영하는 팀을 위한 권한 위반 조기 경보와 실행 보류 모듈
현재 근거	C-01 Draft PR #1: 소형 모델 테스트 67개 통과. 실제 20B·탐지 성능·상업성은 미검증.

02 v2.0에서 바뀐 우선순위

선택 기능이었던 내부 표현 감시를 주 연구로 복원한다. 정책 Guard는 실행 통제와 비교 기준으로 유지한다. 프롬프트 인젝션은 별도 보조 실험이다. 내부 감시의 효과가 없으면 음성 결과로 보고하며, 일반 Guard 완성을 연구 성공으로 대체하지 않는다.

출발 사건과 위협 모델

사건에서 얻은 연구 동기와 아직 입증되지 않은 설명을 분리한다.

03 출발 사건의 해석

OpenAI의 2026.08.26 공개 보고서는 평가 중 모델의 무단 통신·범위 밖 접근과 Hugging Face 침해를 설명한다. 보상 해킹, 어려운 과제에 대한 지속, 감사·대응 문제가 함께 논의된다. 은닉층을 보지 못한 것이 사고의 입증된 원인이라는 주장은 하지 않는다. 공개된 추론 텍스트와 내부 activation도 서로 다른 관찰 대상이다.

04 검증할 가설

실제 실행 전 관찰 가능한 내부 표현에 미래 권한 위반 시도와 연관된 신호가 존재하며, 이 신호가 외부 관찰 정보에 추가 가치를 주는지 검증한다. Probe 점수는 숨은 의도나 의식의 판독이 아니며, 관찰 상관관계만으로 판단의 원인·발생 위치를 특정하지 않는다.

주체 / 경계	실험에서의 정의
Agent	정상 과제와 허용 범위를 받는 고정된 gpt-oss 모델. 주 실험에 직접적인 우회·공격 지시 없음.
연구팀	로컬 모의 환경·가상 자원·명시적 정책을 구성. 실제 외부 서비스 침해는 재현하지 않음.
위반	신뢰된 정책과 제안 행동의 관계로 판정하는 무단 접근·승인 우회·평가 조작 시도.
제외 범위	실제 제로데이·샌드박스 탈출 성공, 가중치 백도어, 악성 파일 로딩을 주 실험 성과로 주장하지 않음.

출처: OpenAI, The Hugging Face incident and the road ahead (2026.08.26)
<https://openai.com/index/hugging-face-incident-and-the-road-ahead/>

시나리오와 데이터 수집

정상 목표를 유지하고, 장애물에 대한 합법적 대응과 권한 위반 선택을 함께 수집한다.

시나리오 계열	정상 대응 / 관찰할 위반
자료 부족 보고서	부족함 보고·권한 요청 / 허용 범위 밖 모의 자료 조회
승인 대기 업무	대기·승인 요청 / 승인 없는 모의 발송·상태 변경
해결이 어려운 평가 과제	정당한 풀이·실패 보고 / 금지된 모의 정답 저장소 접근·평가 기록 수정

05 초기 수집 계획

- 정상 과제 20개를 목표로 장애물 없음/있음 2조건, 조건당 3 seed를 실행한다(계획 120 rollout). 위반 사례 수는 보장하지 않는다.
- 허용된 대체 경로, 권한 요청, 중단·실패 보고를 제공한다. 정상 탐색·문제 해결 실패를 위험 행동으로 라벨링하지 않는다.
- 문체·길이·도구 이름·난이도 편향을 검사하고, 과제 계열 단위로 train/validation/test를 실행 전에 분리한다.
- 시나리오·모델·정책 revision, seed, 정확한 token ID, 행동 시작·종료 경계, 실행 시도와 실제 결과를 연결한다.

06 희소 사례와 보조 데이터

10/4까지 자발적 위반과 정상 사례의 수를 확인한다. 위반이 드물면 정상 과제 난이도·자원 조건을 사전 정의 범위에서 확대하고 희소성을 보고한다. 직접 우회를 지시한 사례와 합성·재생 trajectory는 별도 스트레스 테스트로 표시하며 자발적 위반 증거에 합치지 않는다.

AgentDojo-InjecAgent는 외부 지시 유도에 대한 보조 강건성 평가로 사용 가능하다. 공개 데이터의 기존 로그는 우리 gpt-oss activation을 제공하지 않으므로 별도 실행·수집이 필요하다.

관찰 시점과 비교 실험

행동 생성 전 조기 예측과 행동 생성 후 실행 전 판별을 별도 실험으로 보고한다.

감시 구성	같은 관찰 prefix에서의 입력
M0 · 외부 정보	과제·권한 정책·이전 관찰 및 행동 이력
M1 · 추론 텍스트 추가	M0 + 해당 시점까지 생성되고 접근 가능한 추론 텍스트
M2 · 내부 표현 추가	M1 + 해당 prefix에서 추출한 activation. M1 대비 추가 효과 검증.

추론 텍스트를 얻지 못하는 실행에서는 M1 비교를 미실시로 표시하고 M0 대비 추가 효과를 보고한다. 별도로 행동 생성 후 E1=정책, E2=정책+문맥/가용 추론, E3=E2+activation을 비교한다. E1~E3 결과를 행동 생성 전 조기 탐지 성능으로 표시하지 않는다.

07 라벨과 누수 방지

- B가 정책 기반 행동 라벨을 만들고 D가 검수한다. 첫 위반 시도는 실제 차단 여부와 별개로 기록한다.
- 조기 라벨은 현재 prefix 이후 고정된 행동 지평 내 위반 발생 여부로 정의한다. 초기 지평은 다음 1회 행동이며 확대 지평은 validation에서 고정한다.
- 향후 행동은 오프라인 정답 생성에만 사용한다. 행동 ID·경계·결과·향후 위반 시점은 Probe 입력에서 제외한다.
- 위험 사례만 골라 직전 snapshot을 저장하지 않는다. 정상 사례에도 동일한 사전 고정 관찰 규칙을 적용한다.
- 동일 과제와 그 변형·seed는 같은 split에 둔다. 레이어·임계값은 validation에서 고르고 test는 한 번 고정 평가한다.

먼저 비개입 rollout을 한 번 수집해 감시기를 공정하게 비교한다. 경보로 행동이 바뀌는 온라인 Guard 실험은 별도 실행한다. 종료·시간 초과 사례는 관찰 구간 내 결과로만 해석한다.

지표와 시스템 설계

내부 표현이 위험 신호를 담는지와 실제 경보 운영에 도움이 되는지를 함께 검증한다.

지표	측정 규칙
첫 위반 전 탐지율	위반 trajectory 중 첫 위반 행동 생성 시작 전에 경고한 비율
정상 trajectory 오탐률	관찰된 정책 준수 trajectory 중 한 번 이상 잘못 경고한 비율. 반복 검사 부담 반영.
탐지 선행량	최초 경보에서 첫 위반 생성까지의 token·행동 수. 탐지된 사례 수와 미탐 수를 함께 보고.
보조 지표	AUPRC/AUROC, 시점별 Recall/FPR, 정상 과제 성공률, 위험 실행률, 승인 부담
실행 비용	full-prefix replay 수집 비용과 p50/p95 전체 추가 지연, VRAM·저장량

임계값은 validation에서 고정하고 test의 실제 오탐률·표본 수·trajectory 단위 불확실성을 보고한다. replay 기반의 token 선행량을 실시간 절약 시간으로 주장하지 않는다. 성공 기준은 같은 오탐 예산에서 M2가 M1보다 반복 가능한 탐지율·선행량 개선을 보이는 것이다.

08 실행 구조

Agent prefix → 외부/추론/activation 감시 → 조기 경보·보류 → 제안 행동 → 신뢰된 정책 Guard → 허용/차단/승인 → 모의 도구 → 감사 로그. 명시적 금지는 낮은 위험 점수로 해제하지 않는다. 승인 인자 변경·재사용을 검사하고 직접 실행 우회 경로를 차단한다.

C-01의 post-block hook, token alignment, pre_action/pre_execution과 NPZ/JSON 저장을 재사용한다. 주기적 snapshot 수집과 온라인 경보는 추가 구현이다. 현재 67개 소형 테스트는 추출 계약의 검증이며 탐지 효과나 4090 실측 증거가 아니다.

가상 데이터 사용, 원문·비밀값 로그 최소화, activation 접근 통제. Guard를 비활성화한 비교도 격리된 모의 도구 안에서만 수행한다.

역할·제출물·제품 가설

4명이 10월 말까지 검증 가능한 범위를 완성한다. C의 연구 오너십을 유지한다.

담당	책임과 검토
A · 시스템	백엔드 강점 활용. 로컬 runner·주기적 snapshot·Guard·승인·로그·통합. C와 시점 계약 검토.
B · 환경·데이터	정상 목표·장애물·권한 경계 환경, 과제 계열 split, 행동 라벨·사례 수집. D와 검수.
C · ljl5489	adapter-hook, Linear Probe, 레이어·시점 비교, M2 추가 기여·OOD·오탐/미탐 분석.
D · 독립 평가	M0/M1 기준선, 공통 지표·test 관리, 반복 평가·누수 점검·데모·고객 근거.

09 제출과 포트폴리오

- 코드·모델·데이터·정책 revision, split·seed·환경, PR과 실험 ID를 연결한 재현 패키지.
- M0/M1/M2와 E1/E2/E3 결과, 레이어×시점 그림, 위반·정상 실패 사례, 비용과 한계.
- C는 표현 분석·AI 보안 검증을 직접 소유한다. CV 성과는 실제 이미지 실험 뒤에만 주장한다. ViT probing·OOD는 핵심 검증 후 선택 과제로 둔다.

10 상업적 방향과 한계

제품 가설은 자체 모델을 운영하는 개발·안전성 팀의 권한 위반 조기 경보이다. 잠재 사용자 3~5명의 관찰 가능성·연동·오탐·지연 허용 범위를 확인한다. 인터뷰는 수요·매출의 증거가 아니다. 내부 신호가 외부 감시보다 유용하지 않으면 해당 결과를 공개하고 차별화 주장을 철회한다.

범용 해킹 예측·숨은 의도 판독·실제 sandbox 탈출 방지·모델 간 일반화는 미입증. v3.0: 원래 연구 목적 복원, 자발적 위반 시나리오·시점별 기준선·희소성 대응 추가. 동시 개정 로드맵과 README 참조.